

Episodio 2: Aseguramiento de la calidad, medición y pericias

Fuente para el podcast de repaso del parcial de **Aprobación Directa** de Ingeniería y Calidad de Software (opción múltiple, a libro abierto en papel). Contiene los capítulos 21, 22 y 23 del resumen de estudio `resumen-ad.md`, con su numeración original: las referencias a otros capítulos remiten a ese resumen.

CONTENIDO

21 El aseguramiento de la calidad (PPQA)

23 Las pericias informáticas

22 La medición y el análisis (MA)

21. El aseguramiento de la calidad (PPQA)

Un proyecto atrasado o pasado de presupuesto tiende a saltar el proceso: la revisión prevista no se hace, la trazabilidad no se actualiza, un requerimiento se cambia por teléfono. Nadie lo decide de mala fe; es lo que pasa bajo presión. PPQA existe para que alguien **que no está sometido a esa presión** mire si el proceso se sigue y se lo diga a quien puede corregirlo.

Aseguramiento de la calidad de proceso y de producto (PPQA): proporcionar al personal y a la gerencia una **visión objetiva** de los procesos y de los productos de trabajo asociados.

Es un área **de soporte de nivel 2**. Evalúa los procesos ejecutados y los productos de trabajo contra las **descripciones de proceso, los estándares y los procedimientos** aplicables; es decir, mira la **adherencia**: si se trabajó como estaba definido. Como da servicio a todas las áreas, la práctica genérica **GP 2.9 Evaluar objetivamente la adherencia** se implementa a través de PPQA.

ATENCIÓN PPQA **no evalúa contra requerimientos**: eso es VER. PPQA asegura que **los procesos planificados se implementan**; VER, que **se satisfacen los requerimientos especificados**. Pueden mirar el mismo producto, pero desde perspectivas distintas.

21.1 Objetividad e independencia

La palabra clave del propósito es **objetiva**, y CMMI la descompone en dos ingredientes: **independencia** y **uso de criterios** que minimicen la subjetividad del revisor.

La forma tradicional de lograr independencia es un **grupo de QA independiente del proyecto**. CMMI admite otra: en una organización con **cultura abierta y orientada a la calidad** —lo más factible en organizaciones pequeñas—, la evaluación puede hacerse **entre pares**, con tres condiciones: evaluadores **formados en QA, separados** de quienes desarrollan el producto evaluado, y un **canal independiente** para escalar a la gerencia. Lo que excluye a alguien de evaluar un producto es **haber participado en armarlo**.

ATENCIÓN El criterio rápido para un BP: si el evaluador depende de **la misma cadena jerárquica** que el evaluado —QA dentro de Programación, o SQA y líderes de proyecto bajo el mismo gerente que decide sobre los proyectos—, **no hay independencia** y hay problema de calidad.

21.2 Metas y prácticas

- **SG 1 Evaluar objetivamente los procesos y los productos de trabajo.** SP 1.1 Evaluar objetivamente los procesos · SP 1.2 Evaluar objetivamente los **productos de trabajo** y los servicios.
- **SG 2 Proporcionar una visión objetiva.** SP 2.1 Comunicar y **asegurar la resolución de las no conformidades** · SP 2.2 Establecer **registros**.

La primera meta **evalúa**; la segunda hace que la evaluación **sirva para algo**. Personal externo que controla si se **siguió el procedimiento** definido es SP 1.1; si un **artefacto** cumple la plantilla o la directriz **de la organización**, SP 1.2; **informar, elevar o escalar** una no conformidad y seguirla hasta el cierre, SP 2.1; **registrar** las actividades de QA, SP 2.2. Si el estándar es **del proyecto**, como las reglas de nombres de archivo, no es PPQA sino CM; y usar los informes de no conformidades para **mejorar el proceso de la organización** es OPF.

21.3 Las no conformidades: del hallazgo al cierre

No conformidad (NC): problema identificado en una evaluación que refleja **falta de adherencia** a los estándares, las descripciones de proceso o los procedimientos aplicables.

La SP 2.1 es la práctica más preguntada, porque describe el **ciclo de vida de una no conformidad**: se intenta **resolverla en el proyecto**; si no se puede, se documenta y se **escala** al nivel de gerencia designado; y se **sigue cada una hasta su resolución**. Resolverla admite **tres caminos**: **corregirla, cambiar el estándar o la descripción de proceso** que se incumplió, u **obtener una excepción**.

De ahí salen afirmaciones que los parciales toman casi textualmente:

AFIRMACIÓN	RESPUESTA
"Una auditoría termina cuando se resuelven las no conformidades" (AD 2024)	Verdadera
"El trabajo de auditoría termina cuando se presentan las no conformidades" (AD 2025)	Falsa
"Las no conformidades se intentan resolver a nivel proyecto" (AD 2025)	Verdadera
"El escalamiento es un aviso que dice que no hay no conformidades" (AD 2025)	Falsa: se escala una que no se resolvió
"Las no conformidades deben escalarse aunque se hayan resuelto"	Falsa
"Una no conformidad podría cambiar la descripción de un proceso"	Verdadera

ATENCIÓN El escalamiento no puede faltar. En la corrección de un final, Ripani marcó como lo más importante de la respuesta de PPQA la frase "en caso de persistir esta situación, se podrá elevar el problema a la gerencia": **sin ella, la respuesta era incorrecta**.

21.4 El proceso de aseguramiento de la cátedra

En el proceso que adopta la cátedra, el **equipo de calidad audita periódicamente** los procesos de cada proyecto, desde el arranque hasta el cierre. El **SQA** es el asesor de calidad del proyecto: se asigna **antes de que el pro-**

yecto empiece y reporta al responsable de QA, no al jefe de proyecto. Al planificar, colabora para que las actividades de QA queden en la EDT y en el calendario; durante la ejecución hace las auditorías periódicas e informa los hallazgos; al cierre, asegura que el informe retrospectivo llegue al histórico de la organización.

SITUACIÓN	CUÁNDO SE AUDITA
Regla general	Al final de cada fase del ciclo de vida
El paso entre dos fases se alarga mucho	Revisión bimensual
Mantenimiento evolutivo pequeño	A mitad del proyecto y antes de terminar
Pequeñas peticiones de mantenimiento correctivo	Revisión aleatoria mensual

El reparto que más sirve para los BP: **corregir la no conformidad le corresponde al jefe de proyecto**, pero **auditar, seguir y escalar le corresponde al SQA**. Se escala cuando **no se acuerda** una acción correctiva o cuando la acordada **no se cierra en fecha**, y la decisión de la autoridad superior queda registrada. El proceso y el checklist de la cátedra no nombran igual a quién se escala; lo seguro para el examen es **"fuera del proyecto, a una gerencia independiente de la que maneja el proyecto"**.

Ojo con el sector de SQA de una empresa: suele **evaluar** procesos y productos, que es PPQA, y también **proponer mejoras** a procesos y plantillas, que es OPF. "El sector de SQA comunica por mail los cambios de plantillas" describe un despliegue, OPF SP 3.1, no PPQA.

21.5 PPQA en las preguntas BP

Los dos BP de PPQA de los parciales describen la misma práctica con un final distinto: SQA controla estándares de proceso y de producto, informa las no conformidades, el líder de proyecto debe subsanarlas y SQA vuelve a revisar **a los 15 y a los 30 días**. Lo que cambia es qué pasa si la no conformidad sigue abierta:

	AD 2024	AD 2025
Si la NC sigue abierta...	SQA escala al gerente de desarrollo, "con quien se tiene buena comunicación ya que tanto los PMs como SQA dependen de esa gerencia"	El informe se archiva en "proyectos incumplidores" y queda en el legajo del líder
Lo que falta	Independencia : el gerente que recibe el escalamiento manda también sobre los PMs	Escalamiento y seguimiento hasta el cierre
La opción correcta	"Sí... porque SQA debería depender de otra gerencia para evitar conflicto de intereses al escalar"	"Sí... porque no contempla un mecanismo para controlar, por un grupo externo , que se resuelvan las no conformidades hasta su fin , escalándolas si fuera necesario"

En 2024 hay escalamiento, pero va a quien es **juez y parte**, y la "buena comunicación" es un distractor. En 2025 **no hay escalamiento**: sancionar al líder no resuelve la no conformidad, y usar los datos para evaluar personas es un uso inapropiado (capítulo 22).

ATENCIÓN La opción "no contempla un mecanismo para controlar que se resuelvan las no conformidades" aparece **en los dos parciales**: en 2024 es **falsa**, porque el mecanismo existe; en 2025 es **la correcta**. Hay que leer el final del enunciado, no responder de memoria.

21.6 Los indicadores que da un checklist

El AD de 2025 preguntó qué indicadores se obtienen de un checklist aplicado a 30 casos de uso. El checklist preguntaba si se expresó la **meta**, si la sección de camino alternativo **tiene contenido** y si cada línea del historial de versiones tiene descripción y responsable. Sale "10 casos de uso sin meta", porque se cuentan los "No" de la primera pregunta. **No** sale "20 casos de uso sin caminos alternativos": en esa organización, un caso de uso sin alternativos escribe `<vacío>`, así que la sección igual tiene contenido. Y **no** sale "5 casos de uso sin historial", porque ninguna pregunta controla si el historial existe.

ATENCIÓN Un checklist sólo produce los indicadores que sus preguntas permiten contar.

22. La medición y el análisis (MA)

Las decisiones de un proyecto —¿llegamos a la fecha?, ¿el software está listo para entregar?— se toman igual, con datos o sin ellos. Medir sirve para que se tomen sobre **evidencia objetiva** y no sobre la intuición del líder. Pero medir por medir no sirve: CMMI pide que siempre haya respuesta para "**¿por qué estamos midiendo esto?**".

Medición y análisis (MA): desarrollar y sustentar una **capacidad de medición** que se utiliza para dar soporte a las **necesidades de información de la gerencia**.

Es un área **de soporte de nivel 2**, y su foco inicial es el **proyecto**: estimar con datos, seguir el rendimiento real contra el plan, detectar problemas a tiempo.

22.1 Métrica, medida e indicador

En el habla cotidiana "métrica" y "medida" son sinónimos. En la materia no. La **métrica** es la **forma de medir** un atributo, como contar líneas de código. La **medida** es el **valor** obtenido: 40.000 líneas. El **indicador** es una métrica o combinación de métricas **con criterios de decisión**, como la productividad de los programadores. Las medidas **base** se obtienen midiendo directamente (horas, defectos); las **derivadas** se calculan a partir de otras (densidad de defectos, productividad).

Para decidir qué medir, la guía propone **GQM** (*Goal-Question-Metric*): se parte de una **meta**, se formulan **preguntas** que permitan saber si se la alcanza, y recién entonces se eligen las **métricas** que las responden. Las métricas definidas sin un objetivo explícito no sobreviven.

22.2 Primero alinear, después medir

- **SG 1 Alinear las actividades de medición y análisis.** SP 1.1 Establecer los **objetivos** de medición · SP 1.2 Especificar las **medidas** · SP 1.3 Especificar los procedimientos de **recogida y almacenamiento** · SP 1.4 Especificar los procedimientos de **análisis**.
- **SG 2 Proporcionar los resultados de la medición.** SP 2.1 **Recoger** los datos · SP 2.2 **Analizar** los datos · SP 2.3 **Almacenar** los datos y los resultados · SP 2.4 **Comunicar** los resultados.

La primera meta **define todo antes de medir**: para qué, qué, cómo, cuándo, quién y dónde. Recién la segunda **produce resultados**.

El AD de 2025 lo preguntó con cuatro afirmaciones de un equipo que va a medir plazos, defectos y productividad. Son coherentes con MA la 1, "las métricas deben estar **alineadas con los objetivos del negocio**"; la 3, "do-

cumentar **cómo y cuándo se tomarán los datos y quién los analizará**", y la 4, "el propósito de medir es obtener **evidencia objetiva** para decidir y mejorar". No lo es la 2, "**empezar a recopilar ya, sin definir los procedimientos**": saltea la primera meta. Respuesta: **sólo 1, 3 y 4**.

Usar las métricas para comparar plan contra real y corregir el proyecto **no es MA sino PMC**: MA provee la medición y PMC la usa. Estimar con datos históricos es PP. Y según un resumen de alumno, Ripani lo mostró en clase: las tres horas que un programador pasa revisando el caso de uso de un compañero son VER, y **cargarlas en el parte de horas** es MA SP 2.1.

ATENCIÓN El uso inapropiado de los datos. Al almacenar hay que prevenir que se revele información confidencial, que se interpreten datos fuera de contexto o que se **usen las medidas para evaluar a las personas**. Una "productividad por desarrollador" para premiar o castigar es señal de problema en un BP, igual que medir sin objetivo o recolectar sin procedimiento.

22.3 Métricas de proceso, de proyecto y de producto

Es lo que más se pregunta del área. La guía clasifica las métricas en tres niveles, y los parciales los preguntan de a dos.

	PROYECTO	PROCESO	PRODUCTO
Qué describen	El proyecto y su ejecución: plan contra real	Cómo rinde una actividad del ciclo de vida, para mejorar el proceso	Atributos del software
Ejemplos	Cumplimiento de plazos e hitos, esfuerzo planificado contra real, costo	Defectos detectados por fase, eficiencia de las revisiones, tiempo de corrección	Tamaño, complejidad, defectos en producción, cobertura de pruebas

La regla para decidir: si compara **lo planificado contra lo real de este proyecto**, es de **proyecto**; si mide **cómo funciona una actividad del proceso** —las revisiones, las pruebas, la detección de defectos por fase—, es de **proceso**; si mide un **atributo del software**, es de **producto**.

Con esa regla se resuelve el AD de 2024. Las métricas eran: (1) porcentaje de cumplimiento de los plazos de cada fase, (2) número de defectos identificados por cada fase del ciclo de vida, (3) horas planificadas contra reales por iteración, (4) porcentaje de tareas completadas a tiempo en cada iteración y (5) tiempo promedio de aprobación de código en revisiones. La 1, la 3 y la 4 comparan plan contra real: son de proyecto. La 2 y la 5 miden actividades del proceso. Respuesta: **proceso 2 y 5, proyecto 1, 3 y 4**.

ATENCIÓN La palabra "fase" no decide sola: la métrica 1 habla de fases y es de proyecto, porque mide el cumplimiento del plazo. Y los defectos pueden caer en cualquier nivel: "por fase" los hace de proceso, pero "defectos en producción" serían de producto.

Un indicador se documenta en una **ficha**, con su fórmula y sus **criterios de análisis**: cómo interpretar el valor y qué hacer según el resultado. Las métricas se analizan **apenas se calculan, comparándolas con los objetivos**, y para eso la guía propone las herramientas clásicas: checklist, diagrama de Pareto, histograma, gráfico de control, diagrama causa-efecto.

22.4 Dónde se guardan los datos

Los datos de medición pueden quedar en un repositorio del proyecto o, si se comparten, en el **repositorio de medición de la organización**. Ese segundo repositorio **no lo establece MA sino OPD** (SP 1.4), porque es un activo de la organización (capítulo 7). MA, de nivel 2, guarda los datos que produce; OPD, de nivel 3, crea el

repositorio común. Y las prácticas de MA son **las mismas** en cualquier nivel: lo que aparece en el nivel 3 es ese repositorio.

23. Las pericias informáticas

La informática aparece hoy en casi cualquier conflicto judicial, como herramienta del delito o como su objeto. Y plantea un problema que otras pruebas no tienen en la misma medida: la evidencia digital **se altera con facilidad**. Encender un equipo apagado puede modificar fechas, y ejecutar cualquier programa puede cambiar las fechas de acceso de los archivos. La disciplina existe para que la prueba llegue al juez **indubitable**.

23.1 Forensia, pericia y perito

Informática forense: la ciencia de adquirir, preservar, obtener y presentar datos que han sido procesados electrónicamente y guardados en un medio computacional.

La **pericia informática** es el **acto procesal**: se pide cuando, para descubrir o valorar una evidencia, hacen falta conocimientos especiales. La forensia es la herramienta; la pericia, el acto en que se usa. El **perito** trabaja **en el laboratorio** como asesor científico del juez o el fiscal; el allanamiento y el secuestro **no son tareas suyas**, sino de la **policía con el fiscal**. Conviene que los **puntos de pericia** sean precisos: si el juez pide "buscar evidencia" sin palabras clave, el resultado queda librado al criterio del perito.

23.2 El principio de Locard y las fases

Principio de intercambio de Locard: siempre que dos objetos entran en contacto, transfieren parte del material que incorporan al otro.

Todo delito deja rastro, y **el propio análisis también lo deja**: de ahí la regla que ordena la unidad, **afectar el sistema lo menos posible**. El procedimiento tiene que ser **verificable, reproducible, documentado e independiente** de quién lo haga. Recorre cinco fases: **preservación** (que no se pierdan evidencias), **adquisición** (recolectarlas, con sus hashes), **análisis, documentación** (fotografías, cadena de custodia, bitácora y dos informes, uno ejecutivo y uno técnico) y **presentación** (conclusiones objetivas, sin afirmaciones no demostrables).

ATENCIÓN Las fases **no son estrictamente secuenciales**: están entrelazadas. La documentación empieza en la preservación, no cuando termina el análisis.

23.3 La evidencia y el orden de volatilidad

Evidencia: cualquier prueba que pueda usarse en un proceso legal.

Para servir tiene que ser **admisible** (cumple la legislación), **auténtica** (sin manipulación), **completa, confiable** (sin dudas sobre cómo se obtuvo) y **creíble** (comprensible para un tribunal).

La otra distinción es la **volatilidad**. La memoria, las conexiones de red y los procesos **se pierden al apagar**; el disco y los logs sobreviven. El RFC 3227 manda recolectar **de mayor a menor volatilidad**: registros y caché; tablas de enrutamiento, procesos y memoria; información temporal; disco; logs; topología de la red; y por último documentos. Y prohíbe **apagar** antes de tener lo volátil y **confiar en los programas del sistema investigado**: se usan herramientas propias, desde un medio de sólo lectura.

ATENCIÓN La memoria va antes que el disco: tomar primero la imagen del disco, o apagar el equipo para trabajar tranquilo, contradice el orden.

23.4 La adquisición: imagen forense, hash y bloqueo de escritura

La regla es **no trabajar nunca sobre el original**.

Imagen forense: copia **bit a bit** de la evidencia, que se hace **sólo para analizar sobre ella** y que conserva toda la información, incluida la oculta o remanente.

No hay que confundirla con un **backup**, que es una **copia simple de archivos**: es invasivo, altera la evidencia y no conserva la información oculta o remanente. **El perito no hace backups**: el protocolo los excluye de las tareas periciales.

Para probar que la imagen **no se modificó después**, se calcula su **hash** y se anota en la cadena de custodia: si al recalcularlo coincide, la imagen es la misma. **MD5 tiene colisiones** —dos archivos distintos pueden dar el mismo valor— y conviene **SHA-256 o SHA-512**. Al copiar se usa un **bloqueador de escritura**, por hardware o por software, que impide escribir sobre el original. Su límite se pregunta: un **disco de estado sólido con TRIM** borra las celdas liberadas **con sólo tener corriente**, y el bloqueador no lo evita.

23.5 La cadena de custodia

Entre el secuestro y el perito pasan **mucho tiempo y muchas manos**: allanamiento, comisaría, juzgado, laboratorio. Sin registro no se puede probar que la evidencia no se manipuló.

Cadena de custodia: registro documentado de **dónde, cuándo y quién** descubrió, recolectó, manejó y custodió la evidencia, y de **cada cambio de manos**.

Empieza en el **primer contacto** con la evidencia —normalmente el secuestro—, no cuando llega al perito, y no es una simple formalidad: es la historia clínica de la evidencia. En el protocolo judicial, la integridad física se asegura con **precintos** que la policía coloca desde el secuestro, y sus números de serie van en el acta y en el oficio.

ATENCIÓN Si un precinto llega **roto** y no hay documentada una intervención forense calificada, **no se puede asegurar la integridad y se pierde ese medio de prueba**.

23.6 El protocolo de actuación

El protocolo de actuación para pericias informáticas del Poder Judicial de Neuquén busca **evitar la contaminación de la prueba** y **formalizar** el procedimiento. Lo divide en dos etapas: la **incautación y la cadena de custodia**, a cargo de la policía con el fiscal, en el lugar del hecho; y el **análisis y el informe pericial**, a cargo del perito, en el laboratorio. Por regla se prefiere el **secuestro** a peritar en el lugar, el material llega siempre con el **oficio que fija los puntos de pericia**, y quedan excluidas las tareas ajenas a la disciplina, como transcribir, imprimir o hacer backups.

Lo que más se confunde es qué hacer con un **equipo encendido**, porque las fuentes no dicen lo mismo. **INCIBE**, que le habla a un técnico que responde a un incidente, manda **no apagarlo** hasta haber recolectado la información volátil. El **protocolo de Neuquén**, que le habla a un policía en un allanamiento, manda dejarlo prendido y

consultar a un especialista; sin asesoramiento, **desenchufarlo del lado del gabinete**, nunca de la pared. Hay que identificar qué fuente cita la pregunta.